Cedar Grove Health Partners — Privacy & Security Policy

Effective date: January 1, 2026. Owner: Privacy Officer. Review cycle: annual, or upon any material regulatory or operational change.

This policy establishes Cedar Grove Health Partners's requirements for protecting patient privacy and the security of protected health information (PHI) across all clinics and shared services, consistent with the HIPAA Privacy Rule (45 CFR Part 164, Subpart E) and Security Rule (45 CFR Part 164, Subpart C). It is implemented through the six numbered sections below, each with a dedicated operational procedure maintained separately and cross-referenced to the section it implements.

Access Control and Authentication

Policy statement. Cedar Grove Health Partners ("Cedar Grove") grants access to electronic protected health information (ePHI) strictly on a role-based, least-privilege basis. Every workforce member who requires access to a clinical or administrative system containing ePHI must be issued a unique user identifier; shared or generic logins are prohibited in all clinical systems without exception.

Authentication requirements. All systems that store or transmit ePHI require multi-factor authentication (MFA) for remote access and for any access to the electronic health record (EHR) from outside a Cedar Grove clinic network. Passwords must meet the minimum complexity standard defined in the Cedar Grove IT Security Baseline and must be rotated on a schedule set by the Security Officer, currently every 180 days.

Provisioning and deprovisioning. Access is provisioned only after a signed access request is approved by the requesting workforce member's supervisor and by the Privacy Officer for any request touching PHI outside that member's normal clinical role. Access must be revoked no later than the close of business on a workforce member's last working day, and immediately upon involuntary termination. Quarterly access reviews are performed by department managers to confirm that standing access still matches current job duties; any access that no longer matches duties is removed within five business days of the review.

Session controls. Workstations and EHR sessions automatically lock after 10 minutes of inactivity. Clinical workstations in patient-facing areas must never be left unattended while authenticated.

Related standard: 45 CFR §164.312(a)(1), (d) — Access Control and Person or Entity Authentication.

Individual Rights and Patient Access to Records

Policy statement. Patients (or their authorized personal representatives) have the right to inspect and obtain a copy of their designated record set maintained by Cedar Grove, the right to request amendment of that record, and the right to receive an accounting of certain disclosures, consistent with 45 CFR §164.524, §164.526, and §164.528.

Response timeline. Cedar Grove must act on a patient's access request no later than 30 calendar days after receipt. A single 30-day extension is permitted if the patient is notified in writing, within the initial 30 days, of the reason for delay and the new expected date of completion. Requests submitted through the patient portal for records held entirely in the current EHR should be fulfilled substantially faster than the regulatory maximum — the internal service target is 5 business days.

Form and fees. Records must be provided in the form and format requested by the patient if readily producible in that form (including electronic form for electronic records). Cedar Grove may charge only a reasonable, cost-based fee for copies, calculated per the fee schedule maintained by the Compliance department; no fee may be charged for a patient simply viewing their record in the portal.

Denials. A request may be denied only on the specific grounds enumerated in §164.524 (e.g., psychotherapy notes, information compiled for legal proceedings, or a licensed provider's determination that access is reasonably likely to endanger the patient or another person). Denials on reviewable grounds must offer the patient a right to have the denial reviewed by a licensed healthcare professional who was not involved in the original decision.

Amendment requests. Patients may request amendment of their record; Cedar Grove must act within 60 days (with one permitted 30-day extension with written notice). If an amendment is accepted, Cedar Grove must make reasonable efforts to inform relevant persons the patient identifies and others known to hold the affected information who may have relied on it.

Related standard: 45 CFR §164.524, §164.526, §164.528 — Access, Amendment, and Accounting of Disclosures.

Minimum Necessary Use and Disclosure of PHI

Policy statement. For any use, disclosure, or request for PHI other than treatment (which is exempt from the minimum necessary standard), Cedar Grove workforce members must make reasonable efforts to limit PHI to the minimum necessary to accomplish the intended purpose.

This applies to internal uses (e.g., billing, quality review, peer review) and to disclosures to external parties (e.g., payers, auditors, business associates).

Role-based defaults. The Privacy Officer maintains a role-based access matrix defining, for each job function, the categories of PHI reasonably necessary to that role, the conditions of access, and any relevant restrictions. System access provisioned under Section 1 must conform to this matrix.

Routine and recurring disclosures. For disclosures that occur routinely and recurrently (e.g., standard data feeds to a claims clearinghouse), Cedar Grove uses standard protocols that limit the PHI disclosed to the minimum necessary data elements, reviewed annually by Compliance.

Non-routine requests. Non-routine disclosure requests are evaluated individually against criteria established by the Privacy Officer, considering the nature of the request and the purpose for which the information is sought. Workforce members do not have discretion to disclose whole records where a subset would suffice.

Exceptions. The minimum necessary standard does not apply to: disclosures to or requests by a healthcare provider for treatment; disclosures to the patient (or their personal representative) about their own PHI; uses or disclosures made pursuant to a valid patient authorization; disclosures required by law; or disclosures required for HIPAA compliance investigations by HHS.

Related standard: 45 CFR §164.502(b), §164.514(d) — Minimum Necessary Requirements.

Breach Notification

Policy statement. Cedar Grove treats any acquisition, access, use, or disclosure of unsecured PHI in a manner not permitted by the Privacy Rule as a potential breach requiring immediate risk assessment, unless Cedar Grove demonstrates a low probability that the PHI was compromised based on the four-factor assessment in 45 CFR §164.402.

Internal escalation window. Any workforce member who discovers or suspects a breach must report it to the Privacy Officer within **60 hours** of discovery. The Privacy Officer immediately opens a breach assessment file and convenes the incident response team (Privacy Officer, Security Officer, and, where clinical PHI is involved, the CMO or designee) to complete the four-factor risk assessment covering: (1) the nature and extent of the PHI involved; (2) the unauthorized person who used the PHI or to whom it was disclosed; (3) whether the PHI was actually acquired or viewed; and (4) the extent to which the risk to the PHI has been mitigated.

Individual notification. If the assessment concludes a breach occurred, affected individuals must be notified without unreasonable delay and in no case later than 60 calendar days after discovery, by first-class mail (or email if the individual has agreed to electronic notice) including

a description of the breach, the types of information involved, steps individuals should take to protect themselves, what Cedar Grove is doing to investigate and mitigate, and contact information for follow-up questions.

Regulatory and media notification. Breaches affecting 500 or more individuals in a jurisdiction require concurrent notification to HHS and to prominent media outlets serving that jurisdiction, no later than 60 calendar days after discovery. Breaches affecting fewer than 500 individuals are logged and reported to HHS annually, no later than 60 days after the end of the calendar year in which the breach was discovered.

Business associate breaches. A business associate that discovers a breach of unsecured PHI it holds on Cedar Grove's behalf must notify Cedar Grove without unreasonable delay, consistent with the notification timeline in the applicable Business Associate Agreement (see Section 6).

Related standard: 45 CFR §164.400–414 — Breach Notification Rule.

Workforce Security and Training

Policy statement. Cedar Grove implements workforce security procedures to ensure that access to PHI is appropriate to each workforce member's role and that every workforce member understands their privacy and security obligations before they are granted system access.

Pre-access training. All new workforce members complete HIPAA Privacy and Security orientation training before their first day of unsupervised access to any system containing PHI. Training covers the Privacy Rule's core permitted uses and disclosures, the minimum necessary standard (Section 3), patient rights (Section 2), breach reporting obligations (Section 4), and Cedar Grove's acceptable use policy for clinical systems and devices.

Recurring training. All workforce members complete refresher HIPAA training semi-annually (twice yearly), and additional targeted training whenever a material policy change occurs (for example, a change to the breach notification window) or following a workforce-related incident that indicates a training gap.

Sanctions. Workforce members who violate this policy or applicable HIPAA requirements are subject to sanctions under the Cedar Grove disciplinary policy, up to and including termination, regardless of whether the violation resulted in an actual breach.

Workforce clearance and supervision. Department managers are responsible for ensuring that workforce members under their supervision, including temporary staff and students on clinical rotations, operate only within the access granted under Section 1 and receive role-appropriate supervision until training is complete.

Related standard: 45 CFR §164.308(a)(3), (a)(5) — Workforce Security and Security Awareness and Training.

Business Associate Agreements and Vendor Risk Review

Policy statement. Cedar Grove may disclose PHI to a vendor acting as a business associate only after executing a Business Associate Agreement (BAA) that meets the requirements of 45 CFR §164.504(e), and only after that vendor has passed the vendor risk review described below.

Vendor risk review. Before onboarding any vendor that will create, receive, maintain, or transmit PHI on Cedar Grove's behalf, the Security Officer completes a risk review covering: the vendor's own security certifications (e.g., SOC 2 Type II, HITRUST), its subcontractor/sub-processor chain and whether each sub-processor is itself bound by a HIPAA-compliant agreement, its data encryption practices at rest and in transit, its incident and breach notification commitments, and its data return or destruction practices upon contract termination.

BAA required terms. Every Cedar Grove BAA must, at minimum: permit the vendor to use or disclose PHI only as permitted by the agreement or required by law; require appropriate safeguards to prevent unauthorized use or disclosure; require the vendor to report any security incident or breach of unsecured PHI to Cedar Grove; require the vendor to ensure any subcontractors agree to the same restrictions; make PHI available to satisfy patient access and amendment rights under Section 2; and require return or destruction of PHI at termination, or an explanation of why that is infeasible.

Ongoing monitoring. Vendors handling PHI are reassessed annually, or immediately upon notice of a security incident at the vendor, a material change in the vendor's subcontractor chain, or an adverse security certification finding. The vendor registry, including BAA status and last review date for every active vendor, is maintained by Compliance and reviewed quarterly by the Privacy Officer.

Related standard: 45 CFR §164.502(e), §164.504(e) — Business Associate Contracts and Other Arrangements.